

CGE-P LAB CURRICULUM · V2

# CGE-P Lab Curriculum (v2)

Eleven labs and a capstone brief. Every lab produces an artifact the capstone consumes.

---

For reading. Code lines wrap to fit the page; copy code from the repository, not the PDF.

**GRC Engineering Club**

grcengclub.com · based on GRCEngClub/cgep-labs

FROM CHECKBOX GRC TO ENGINEERED SYSTEMS

**This PDF is for reading.** Long code lines wrap to fit the page, so copy commands and code from the repository ( `GRCEngClub/cgep-labs` ), not from the PDF.

**Where these live.** Upstream, the guides are `guides/*.md` in `GRCEngClub/cgep-labs` and the companion code is `reference/lab-X-Y/`. These drafts sit in `docs/` so you can build the reference workspaces from them before deciding what to upstream. Every code block here is written to pass that repo's CI: `terraform fmt -check -recursive`, `terraform validate -backend=false`, `opa test`, and `trestle validate`.

This is the v2 rewrite. It differs from v1 in one governing way: **a lab may only cite a control it actually implements**. Where v1 claimed a control the code didn't satisfy, v2 either implements it or moves the claim to the lab that earns it. Where a mapping is arguable, the lab says so and defends it, because teaching students that control mappings are arguments rather than lookups is the single most transferable thing in this course.

## Start here

**The Plain English Guide** is the companion to everything below. The labs tell you what to type; that guide explains what it means, where every magic string and constant came from, and which choices are actually yours. Read it first, or keep it open alongside the labs. It is not a lab and creates nothing.

## Reading order

| #   | Lab                                    | Cloud | Produces                                                                                      |
|-----|----------------------------------------|-------|-----------------------------------------------------------------------------------------------|
| 0.0 | <b>Plain English Guide</b>             | none  | Concepts, decoder ring, decision tables. <b>New in v2.</b> Not a lab.                         |
| 0.1 | <b>Prerequisites &amp; Credentials</b> | both  | Sandbox account, short-lived credentials, toolchain, <b>budget alarms</b> . <b>New in v2.</b> |
| 2.2 | <b>Remote State Backend</b>            | AWS   | S3 + DynamoDB state backend. <b>New in v2.</b>                                                |
| 2.3 | <b>First Compliant Resource</b>        | AWS   | <code>compliant-s3</code> primitive with CMK, TLS enforcement, lifecycle.                     |
| 2.4 | <b>Modules for Compliance</b>          | GCP   | Reusable module discipline, CMEK, consumer pattern.                                           |
| 2.5 | <b>IaC as Compliance Evidence</b>      | AWS   | Object Lock evidence vault + <code>capture-evidence.sh</code> .                               |
| 3.3 | <b>Writing Rego</b>                    | GCP   | Policy library with metadata and test fixtures.                                               |
| 3.4 | <b>Confest + Terraform</b>             | AWS   | AWS policy variants + <code>policy-gate.sh</code> .                                           |
| 4.3 | <b>GRC Evidence Pipeline</b>           | AWS   | <code>.github/workflows/grc-gate.yml</code> .                                                 |

| #   | Lab                   | Cloud | Produces                                                    |
|-----|-----------------------|-------|-------------------------------------------------------------|
| 4.4 | Chain of Custody      | AWS   | Cosign signing wired into the vault.                        |
| 5.2 | AWS Security Services | AWS   | CloudTrail, Config, Security Hub, Athena review.            |
| 5.4 | GCP Security Services | GCP   | Org Policy, Workload Identity Federation, Data Access logs. |
| 6.1 | Introduction to OSCAL | none  | Component definition + profile, validated.                  |
| 7.1 | Capstone Brief        | AWS   | The graded deliverable.                                     |

## The shared baseline

Every S3 bucket built anywhere in this curriculum enforces the same floor. Labs do not re-argue it; they cite it. If you change something here, it changes everywhere, which is the point.

| Property                              | Resource                                                            | Control         | Why it is in the floor                                                                                                 |
|---------------------------------------|---------------------------------------------------------------------|-----------------|------------------------------------------------------------------------------------------------------------------------|
| Customer-managed KMS key, rotation on | <code>aws_kms_key</code>                                            | SC-12, SC-13    | Key custody and rotation are yours, not the platform's.                                                                |
| SSE-KMS with bucket keys              | <code>aws_s3_bucket_server_side_encryption_configuration</code>     | SC-28, SC-28(1) | Bucket keys cut KMS request cost by up to 99%, and are <b>required</b> when the bucket receives S3 server access logs. |
| Versioning                            | <code>aws_s3_bucket_versioning</code>                               | CP-9, SI-7      | Prior object states survive deletion and overwrite.                                                                    |
| All four public-access-block flags    | <code>aws_s3_bucket_public_access_block</code>                      | AC-3            | Two axes (ACL vs policy) by two states (new vs existing).                                                              |
| ACLs disabled                         | <code>aws_s3_bucket_ownership_controls = BucketOwnerEnforced</code> | AC-3, AC-6      | AWS default since April 2023. An ACL-enabled bucket is itself a CIS and Security Hub finding.                          |
| Deny non-TLS                          | <code>aws_s3_bucket_policy (aws:SecureTransport)</code>             | SC-8, SC-8(1)   | <b>The gap that v1 never closed anywhere.</b>                                                                          |
| Deny wrong-key uploads                | <code>aws_s3_bucket_policy (s3:x-amz-server-side-encryption)</code> | SC-28           | Turns encryption from a default into an enforced condition.                                                            |
| Lifecycle rules                       | <code>aws_s3_bucket_lifecycle_configuration</code>                  | AU-11, SA-9     | Retention is a control, and unbounded logs are an unbounded bill.                                                      |

| Property           | Resource                           | Control    | Why it is in the floor                                      |
|--------------------|------------------------------------|------------|-------------------------------------------------------------|
| Four required tags | provider <code>default_tags</code> | CM-6, CM-8 | Boundary enumeration by API call instead of by spreadsheet. |

Two properties are **not** in the floor, deliberately, and each lab that needs them says so: Object Lock (Lab 2.5, evidence only) and cross-account log delivery (documented, not built, see Lab 5.2).

## What changed from v1, and why

Read this section if you taught or took v1. Everything here is a correction, not a preference.

**1. A state backend now exists (new Lab 2.2).** v1 built no backend anywhere, yet Lab 4.3's pipeline ran `terraform init` on a fresh runner and the capstone required `Apply` on merge to `main`. With local state, that runner starts with empty state, so the first apply after a merge either collides with existing resources or duplicates them. The capstone's Layer 3 was not completable as written. Lab 2.2 fixes it before anything depends on it.

**2. Lab 2.3's log bucket is now versioned.** v1's architecture prose said "both buckets enforce ... versioning" while its code versioned only the primary. The bucket holding audit records was less protected than the bucket holding data. Verified against v1's own resource count: 11 resources, no `aws_s3_bucket_versioning.log`.

**3. TLS enforcement exists (SC-8).** v1 never used `aws:SecureTransport` in any lab, and never cited SC-8. Encryption at rest was covered in Chapter 2; encryption in transit was covered nowhere. This is also a `tfsec HIGH`, meaning v1's own Chapter 4 gate would have failed v1's own Chapter 2 artifact.

**4. AWS KMS is taught before the capstone requires it.** v1 taught CMEK only in Lab 2.4, on GCP. The capstone's Layer 1 required AWS CMKs with rotation. Students met `aws_kms_key` for the first time in a graded deliverable.

**5. Log delivery uses a bucket policy, not an ACL.** v1 set `BucketOwnerPreferred` and applied a `log-delivery-write` ACL, re-enabling ACLs on the log bucket to do it. That works, and it trips Security Hub's "S3 general purpose buckets should have ACLs disabled." v2 uses the modern grant to `logging.s3.amazonaws.com` with `aws:SourceArn` and `aws:SourceAccount` confused-deputy conditions. The `depends_on` dance disappears with it.

**6. AU-6 is no longer claimed by Lab 2.3.** AU-6 is audit *review, analysis, and reporting*. Shipping logs into a bucket is AU-3 plus AU-11. v1 claimed AU-6 in a lab where nothing read the logs. v2 moves the claim to Lab 5.2, which now stands up an Athena table over the trail and runs a query, because that is what AU-6 costs.

**7. Versioning's control mapping is defended, not asserted.** v1 mapped versioning to CM-6. v2 maps it to CP-9 and SI-7, and on log buckets to AU-9, and explains why CM-6 was the weaker argument.

**8. CloudTrail data events are on for the evidence vault (Lab 5.2).** v1 said "we do not enable data events here," which left object-level access to the evidence vault unaudited. The vault is the one bucket where you must know who read what. Cost is called out explicitly.

## Cost and time

---

v2 costs more than v1. That is the honest consequence of "production grade," and every lab states its own number. Running the whole curriculum and destroying same-day:

| Lab      | Marginal cost                          | Time      |
|----------|----------------------------------------|-----------|
| 0.1      | free (sets the budget cap)             | 90 min    |
| 2.2      | under \$0.01                           | 20 min    |
| 2.3      | ~\$1/mo per KMS key, prorated to cents | 60-75 min |
| 2.4      | ~\$0.06 per key version per month      | 45-60 min |
| 2.5      | under \$0.01                           | 45 min    |
| 3.3, 3.4 | free (plan only)                       | 105 min   |
| 4.3, 4.4 | free                                   | 150 min   |
| 5.2      | \$1-8 if left running a month          | 75 min    |
| 5.4      | pennies                                | 75-90 min |
| 6.1      | free                                   | 60-75 min |

**Destroy same-day and the whole curriculum lands under \$5.** Leave Security Hub and a few KMS keys running for a month and it is \$10-15. KMS keys bill \$1/month each whether you use them or not, and a scheduled key deletion still bills through its waiting period.

## Conventions

---

- Every lab states cost and time before the first command.
- Every control citation appears as a comment at the exact line that enforces it.
- Every lab ends with cleanup that actually works, verified against versioned and Object-Locked buckets.
- Placeholders are `<your-sandbox>`, `<your-vault>`, `your-gcp-project`. Substitute yours.
- No lab asks you to run something it has not told you the cost of.